ActARion

WHITEPAPER · AR SECURITY MANUFACTURING

IT and security dossier: AR and AI on the shop floor

What IT/OT, the CISO and the DPO need to assess before digital and AR work instructions go live: devices, networks, identity, data, GDPR, the EU AI Act and NIS2



ActARion whitepaper series · 05

13 min read · November 2026

IN SHORT

AR and AI work instructions can be deployed securely when they are treated like any other operational application: managed devices, a segmented network path that never touches OT control traffic, SSO with role-based access, minimal and documented data collection, a DPIA, early works council involvement, EU hosting and human review of every AI-generated instruction before release.

For: IT/OT managers, CISOs, data protection officers and works council liaisons in manufacturing

KEY TAKEAWAYS

01 Treat tablets, phones and headsets as managed endpoints: MDM enrolment, kiosk or shared-device mode, remote wipe and controlled updates.

02 Keep the instruction platform outside the OT control zone; operators need content, not access to PLCs or SCADA.

03 Photos, video and step logs are personal data as soon as they can be linked to a worker. Run a DPIA and agree the use of performance data with the works council (OR / Betriebsrat) before the pilot.

04 Under the EU AI Act, AI-drafted work instructions are usually not high-risk, but human review, traceability and AI literacy are sensible controls from day one.

Contents

01 Why should IT and security be involved before the first pilot?

02 How do you manage tablets, phones and AR headsets?

03 How do you connect AR to the network without touching OT?

04 Which data is stored, and what does GDPR require?

05 What does the EU AI Act mean for AI-generated work instructions?

06 Does NIS2 apply, and how do identity and SSO fit in?

07 Which questions belong in the vendor security questionnaire?

01 CHAPTER 1

Why should IT and security be involved before the first pilot?

Because shop-floor AR and AI touch devices, networks, identities and personal data at the same time. Involving IT/OT, the CISO and the DPO at the start avoids a pilot that works operationally but cannot be scaled.

Digital and AR work instructions usually start in operations: a plant manager wants faster onboarding, quality wants fewer deviations, maintenance wants remote support. The technology is then chosen on usability. Security questions surface later, often at the moment a pilot has to become a rollout, and that is the most expensive moment to discover that devices are unmanaged or that video is stored outside the EU.

This dossier is written for the people who must say yes to that rollout: IT and OT managers, the CISO, the data protection officer (DPO) and whoever liaises with the works council. It describes what a typical deployment looks like, which risks are real, and which questions to put to any vendor, including the platform ActARion implements, DeepSight.

What a typical deployment looks like

Component	What it does	Main security question
Authoring environment (browser)	Engineers and trainers create and approve instructions	Who may publish, and is there an approval trail?
Player app on tablet, phone or headset	Operator follows steps, takes photos, confirms checks	Is the device managed and can it be wiped?
Cloud platform	Stores instructions, media, execution logs	Where is data hosted and who can access it?
AI services	Draft instructions from documents, video or audio; translate	Which data is sent to which model, and is it reused for training?
Integrations (optional)	ERP/MES/CMMS, identity provider, LMS	Which direction does data flow, with which credentials?

Definition: connected worker application

A connected worker application is software that gives frontline staff digital instructions, checklists and support on a mobile or wearable device and records what was done. From a security perspective it is a business application with mobile endpoints and personal data, not an OT system.

02 CHAPTER 2

How do you manage tablets, phones and AR headsets?

Enrol every device in mobile device management (MDM), run it in a locked-down kiosk or shared-device profile, and control app and firmware updates centrally. Headsets need the same treatment as tablets, even if MDM support differs per model.

Shop-floor devices are shared, carried around, dropped and occasionally taken home. The baseline is therefore stricter than for an office laptop. Most organisations already have an MDM or unified endpoint management (UEM) platform; the work lies in defining a shop-floor profile.

Baseline device profile

- Device enrolled in MDM/UEM before it reaches the line; no personal enrolment.
- Kiosk or single-app mode where possible, so the device only runs the instruction app.
- Shared-device mode with individual login per shift instead of one generic account.
- Screen lock, encryption at rest and automatic logout after inactivity.
- Camera and microphone permissions limited to the instruction app.
- Remote lock and wipe tested, including for headsets.
- App and OS updates staged: first a test device, then the line, outside production peaks.
- Physical labelling and an asset register so lost devices are noticed quickly.

AR headsets: what is different

Head-mounted displays often run their own operating system and support only part of the MDM feature set. Ask the vendor which MDM platforms are supported, how firmware updates are distributed and whether spatial maps or room scans are stored on the device or in the cloud. Spatial data can reveal the layout of a production hall, which some sites classify as confidential.

Bring-your-own-device (BYOD) is rarely suitable on the shop floor. If contractors or service engineers must use their own phones, restrict them to a containerised app profile and to guest content without access to internal instructions.

03 CHAPTER 3

How do you connect AR to the network without touching OT?

Put shop-floor devices on a dedicated wireless segment that has internet or data-centre access to the platform but no route to the control network. Integrations with MES or CMMS run server-to-server through the DMZ, never from the device.

Most plants follow a zone-and-conduit model in the spirit of IEC 62443 or the Purdue reference model: enterprise IT at the top, a demilitarised zone (DMZ) in the middle, and control systems (PLC, SCADA, DCS) below. Instruction devices belong on the IT side of that boundary, even though they are physically next to the machine.

01 **Create a dedicated SSID and VLAN**
Separate shop-floor devices from office clients and from OT. Use certificate-based Wi-Fi authentication (802.1X) rather than a shared password.

02 **Allow only what the app needs**
Outbound HTTPS to the platform's documented endpoints. Request the list of domains and ports from the vendor and allowlist them in the firewall or proxy.

03 **Block lateral traffic**
No routes from the device VLAN to PLCs, HMIs or engineering workstations. Remote support sessions must not become a back door into OT.

04 **Integrate in the DMZ**
If step data must reach the MES or CMMS, use a server-side connector or middleware in the DMZ with a dedicated service account and logging.

05 **Plan for poor coverage**
Check Wi-Fi coverage at every workstation. Ask whether instructions can be cached offline and how logs are synchronised afterwards.

Remote expert sessions

Live video calls with an off-site expert are often the most valuable and the most sensitive feature. Agree which areas may be filmed, whether sessions are recorded, where recordings are stored and how long they are kept.

04 CHAPTER 4

Which data is stored, and what does GDPR require?

Photos, video, audio and step logs become personal data as soon as they can be linked to an identifiable worker. GDPR then requires a lawful basis, data minimisation, defined retention and, where monitoring is systematic, a data protection impact assessment (DPIA).

Data inventory

Data type	Example	Personal data?	Typical retention question
Instruction content	Steps, 3D models, reference photos	Rarely (unless people are visible)	Version history as long as the product is supported
Execution logs	Who did which step when, duration, confirmations	Yes	As long as needed for quality traceability
Evidence photos	Photo of torque setting or label	Possibly (faces, badges)	Linked to batch or work order retention
Video and audio	Remote support, recorded demos for AI drafting	Yes	Short by default; extend only with reason
Account data	Name, role, language, qualifications	Yes	Duration of employment plus defined period
Spatial data	Room scans, anchors	Usually not, but may be confidential	Delete when the line changes

DPIA: when and how

Article 35 GDPR requires a DPIA where processing is likely to result in a high risk, in particular systematic monitoring. Step logs with timestamps per named operator can be used to monitor performance,

so most DPOs will ask for a DPIA, or at least a documented screening. Do it during pilot design, not after go-live.

- Purpose described: work instruction, quality traceability, training, not individual performance ranking.
- Lawful basis documented (usually legitimate interest or legal obligation for traceability).
- Data minimisation: pseudonymous or team-level reporting where names are not needed.
- Retention periods per data type, enforced technically.
- Processor agreement (DPA) with the vendor and list of sub-processors.
- Transfers outside the EEA identified and covered, or avoided.
- Information to employees in plain language, in their working languages.

Works council: OR and Betriebsrat

In the Netherlands, Article 27 of the Works Councils Act (WOR) gives the ondernemingsraad a right of consent for regulations on personnel tracking systems and on processing personal data of employees. In Germany, Section 87(1)(6) of the Works Constitution Act (BetrVG) gives the Betriebsrat co-determination over technical systems that are suitable to monitor the behaviour or performance of employees. Suitability is enough: it does not matter whether management intends to use the data that way.

In practice this means an agreement (in Germany a Betriebsvereinbarung) that defines which data is collected, who sees individual data, that it is not used for individual performance assessment unless agreed, and how employees are informed. Involving the works council early tends to speed up the roll-out because acceptance on the floor improves.

Hosting

Confirm the hosting region and all sub-processors of the platform in writing. Ask the same question for AI services, which are sometimes processed in a different region from the main platform.

05 CHAPTER 5

What does the EU AI Act mean for AI-generated work instructions?

Using AI to draft, translate or summarise work instructions is generally not a high-risk use under the EU AI Act. The relevant obligations are transparency, AI literacy and, above all, sound human review before any AI-drafted instruction reaches the floor.

The EU AI Act (Regulation (EU) 2024/1689) applies in stages. Prohibited practices and AI literacy have applied since 2 February 2025, and rules for general-purpose AI models since 2 August 2025. The Act became generally applicable on 2 August 2026.

In 2026 the EU adopted the Digital Omnibus on AI, which postponed the high-risk deadlines. It was published in the Official Journal on 24 July 2026. Obligations for stand-alone high-risk systems listed in Annex III, including AI used in employment and worker management, now apply from 2 December 2027. Obligations for high-risk AI embedded in regulated products under Annex I apply from 2 August 2028. The Omnibus also reframed the AI literacy article so that it supports AI literacy rather than placing a direct duty on providers and deployers. Check the latest guidance before you finalise a policy, because implementing guidelines are still being published.

Where AR and AI instructions fit

Use	Likely classification	What to do
AI drafts steps from a manual or video; an engineer reviews and publishes	Not high-risk	Human review, version control, label AI-assisted content internally
AI translates approved instructions	Not high-risk	Review by a native speaker for safety-critical steps
AI assistant answers operator questions from approved content	Usually not high-risk; transparency applies	Tell users they are interacting with AI; restrict to approved sources
AI evaluates individual worker performance or allocates tasks	Potentially high-risk (Annex III, employment)	Avoid in scope, or treat as a separate project with legal review
Emotion recognition of workers	Prohibited in the workplace (with narrow exceptions)	Do not use

Human review workflow for AI-drafted instructions

01 **Generate as draft**
AI output is always saved as a draft, never published directly.

02 **Technical review**
A process or maintenance engineer checks every step, tolerance, torque value and tool reference against the source.

03 **Safety and quality review**
HSE checks warnings and PPE; quality checks critical-to-quality steps and inspection points.

04 **Approve and version**

Named approver, date and version are recorded. Previous versions remain retrievable.

05 **Validate on the line**

An experienced operator runs the instruction once; findings feed back before wide release.

Model training on your data

Ask explicitly whether your documents, images or video are used to train or improve the vendor's or a third party's AI models, and whether you can opt out. Get the answer in the contract, not only in a sales presentation.

06 CHAPTER 6

Does NIS2 apply, and how do identity and SSO fit in?

Many manufacturers, food producers and energy companies fall within the scope of NIS2, which makes supplier security an explicit management responsibility. Single sign-on with role-based access is the most effective single control for a shop-floor platform.

The NIS2 Directive (EU) 2022/2555 extends cybersecurity obligations to medium and large entities in sectors such as energy, food, manufacturing of machinery, medical devices and chemicals. Article 21 lists the risk-management measures, which explicitly include supply chain security, access control and the use of multi-factor authentication. National transposition and timing differ per member state, so check the status in the Netherlands, Belgium, Germany, Austria and Switzerland (which is outside the EU but often aligns) with your legal team.

For an instruction platform, NIS2 mainly means that you must be able to show you assessed the supplier, that access is controlled and that incidents are reported to you quickly enough to meet your own reporting obligations.

Identity and access

- **SSO** via your identity provider (SAML 2.0 or OpenID Connect) for authors, approvers and administrators. Support: [SSO-protocols: confirm].
- **Multi-factor authentication** for every role that can publish or change content.
- **Operator login** that fits the shop floor: badge, QR code or short PIN on a managed device, linked to a named identity.

- **Role-based access**: author, reviewer, approver, operator, administrator, external expert. Separate site and line permissions.
- **Automated provisioning and deprovisioning** (for example SCIM), so leavers lose access the same day.
- **Audit logs** of logins, publications and administrative changes, exportable to your SIEM.

07 CHAPTER 7

Which questions belong in the vendor security questionnaire?

Use a short, specific questionnaire that covers certification, hosting, data handling, AI, access, resilience and exit. Ask for evidence, not yes/no answers.

Most organisations have a standard supplier questionnaire. The list below adds the questions that are specific to AR and AI on the shop floor. ActARion supports customers in collecting these answers from DeepSight and in documenting them for the DPO and works council.

- Information security certification and scope: [ISO 27001: confirm].
- Hosting location and sub-processors for platform, media storage and AI services: [EU-hosting: confirm].
- Encryption in transit (TLS version) and at rest; key management.
- Most recent independent penetration test, scope and remediation status: [pen test: confirm date and scope].
- Supported MDM platforms and headset models; offline behaviour.
- SSO, MFA, SCIM and role model; audit log export.
- Data retention settings per data type; deletion on request and at contract end.
- Use of customer data for AI model training; opt-out; which AI models and where they run.
- Human approval workflow and version control for AI-generated content.
- Incident notification time and contact; alignment with NIS2 and GDPR breach timelines.
- Business continuity: uptime target, backups, restore tests.
- Exit: export format for instructions, media and logs.

A practical sequence

01 **Week 1: scoping**
Define pilot line, device type, data to be collected and integrations. Invite IT/OT, DPO and works council liaison.

02 **Week 2–3: assessment**
Vendor questionnaire, DPIA screening, network design, MDM profile.

03 **Week 3–4: agreements**
Processor agreement, works council agreement on data use, internal AI review procedure.

04 **Pilot**
Run with the agreed controls; log security findings alongside operational KPIs.

05 **Rollout decision**
Review findings, adjust controls, then scale per site.

0
routes from device VLAN to OT control network

100%
of AI-drafted instructions reviewed by a named approver

1 day
target for revoking access of leavers

?

Frequently asked questions

Is AR on the shop floor an OT security risk?

Not if it is designed correctly. Instruction devices need content from a business application, not access to control systems. Keep them on a separate network segment without routes to PLCs or SCADA, and run any MES or CMMS integration server-side through the DMZ.

Do we need a DPIA for digital work instructions?

Often yes, or at least a documented screening. Step logs linked to named operators can be used to monitor performance, which is a typical DPIA trigger under Article 35 GDPR. Your DPO decides; do it during pilot design.

Does the works council have to agree?

In the Netherlands the ondernemingsraad has a right of consent on personnel tracking systems and employee data processing (Article 27 WOR). In Germany the Betriebsrat co-determines on systems suitable for monitoring behaviour or performance (Section 87(1)(6) BetrVG). Involve them early.

Are AI-generated work instructions high-risk under the EU AI Act?

Generally not, when AI only drafts or translates content that people review and approve. AI that evaluates or manages individual workers can fall under Annex III, whose obligations now apply from 2 December 2027 after the Digital Omnibus on AI.

Can the platform be hosted in the EU?

This must be confirmed per vendor and per component, including AI services. ActARion can collect this information for DeepSight during the intake.

SOURCES

1. Regulation (EU) 2024/1689 (Artificial Intelligence Act), EUR-Lex — https://eur-lex.europa.eu/eli/reg/2024/1689/oj
2. Future of Privacy Forum: The AI Act implementation timeline – what changes under the AI Omnibus? — https://fpf.org/blog/the-ai-act-implementation-timeline-what-changes-under-the-ai-omnibus
3. Sidley Data Matters: EU lawmakers reach provisional agreement to delay key EU AI Act obligations — https://datamatters.sidley.com/2026/06/22/eu-lawmakers-reach-provisional-agreement-to-delay-key-eu-ai-act-obligations/
4. Regulation (EU) 2016/679 (GDPR), EUR-Lex — https://eur-lex.europa.eu/eli/reg/2016/679/oj
5. Directive (EU) 2022/2555 (NIS2), EUR-Lex — https://eur-lex.europa.eu/eli/dir/2022/2555/oj
6. Wet op de ondernemingsraden (WOR), wetten.overheid.nl — https://wetten.overheid.nl/BWBR0002747
7. Betriebsverfassungsgesetz § 87 Mitbestimmungsrechte — https://www.gesetze-im-internet.de/betrvg/__87.html

ActARion



Book a free intake call

Want to prepare your security assessment, DPIA and works council agreement before a pilot starts? Book a free intake call with Jack Kessels (Benelux) or Mark Dercksen (DACH). We bring the vendor answers and a proven pilot set-up.

Book a free intake call **Calculate your ROI**

Jack Kessels · Benelux Mark Dercksen · Founder · DACH hello@actarion.com

© 2026 ActARion. This whitepaper is general information, not legal or financial advice.